

Swift Server Hardening Evidence

Field	Value
Document ID	EVD-SWIFT-HARDENING-001
Version	1.0
Owner	[SWIFT Infrastructure Owner]
Effective Date	[Effective Date]
Framework	SWIFT Customer Security Controls Framework
Classification	Confidential

Purpose

This evidence document records and describes the configuration baseline evidence used to demonstrate that SWIFT-related servers are hardened, consistently configured, and protected against unauthorised or insecure changes.

The purpose of this evidence is to show that servers supporting SWIFT messaging, connectivity, security, monitoring, administration, and supporting infrastructure are configured according to approved hardening standards before use and remain aligned with those standards during operation.

This document is intended to support internal control assurance, independent review, audit activity, and SWIFT security attestation by providing a clear, traceable evidence set for server hardening configuration baselines.

What This Evidence Demonstrates

This evidence demonstrates that the organisation has applied, validated, and retained configuration baselines for in-scope SWIFT servers. Specifically, it demonstrates that:

- A formally approved hardening baseline exists for each relevant server operating system and server role.
- SWIFT-related servers are built from approved secure configuration standards.
- Unnecessary services, ports, protocols, software, accounts, and administrative tools are disabled or removed.
- Security settings are configured to reduce the risk of unauthorised access, malware execution, privilege misuse, insecure network exposure, and configuration drift.
- Administrative access is restricted, monitored, and aligned with the principle of least privilege.
- Logging, time synchronisation, authentication, session management, and endpoint protection settings are enabled and configured appropriately.
- Configuration baselines are periodically reviewed and updated in response to technology changes, threat intelligence, vendor guidance, and operational requirements.
- Deviations from the approved baseline are documented, risk-assessed, approved, time-bound where applicable, and subject to periodic review.
- Evidence has been collected from authoritative sources such as configuration management platforms, endpoint management tools, server build records, security scanning tools, and manual validation records.
- The evidence is complete, current, traceable to specific systems, and protected against unauthorised modification.

This evidence should allow a reviewer to confirm that hardening is not merely defined as a requirement, but has been implemented on the servers that support the SWIFT environment.

Scope

This evidence applies to all servers that host, support, secure, monitor, administer, or provide infrastructure services to the organisation's SWIFT environment.

In-scope systems include, where applicable:

System Category	Examples of In-Scope Systems	Evidence Expected
SWIFT messaging servers	SWIFT interface servers, messaging application servers, communication components	Baseline build record, hardening checklist, configuration scan, access control evidence
SWIFT connectivity servers	VPN, connectivity, proxy, secure gateway, or communication relay servers supporting SWIFT traffic	Network service hardening evidence, port and protocol validation, secure configuration records
Security infrastructure servers	Authentication, privileged access, endpoint protection, vulnerability scanning, logging, monitoring, certificate, and key management servers supporting SWIFT	Security configuration exports, administrative access review, logging and alerting evidence
Administration servers	Jump servers, bastion hosts, management servers, deployment servers used for SWIFT administration	Secure build evidence, restricted access configuration, session logging evidence
Supporting infrastructure servers	Directory services, DNS, NTP, backup, patch management, configuration management, and monitoring servers used by the SWIFT environment	Baseline compliance records, role-based configuration evidence, service hardening evidence
Virtualisation or hosting platforms	Hypervisors, management appliances, dedicated hosting nodes, or cloud-hosted instances supporting SWIFT servers	Host hardening evidence, management access control, platform security configuration evidence

Out of scope:

- End-user workstations not used for SWIFT administration.
- General corporate servers with no connectivity, administrative, monitoring, authentication, or dependency relationship to the SWIFT environment.
- Network device hardening evidence, unless the device is operating as a server-based SWIFT support component.
- Application-specific configuration evidence that is not part of the underlying server operating system or platform hardening baseline.

Where there is uncertainty about whether a server is in scope, the system owner must document the rationale and obtain confirmation from the [SWIFT Security Officer] or equivalent accountable role.

Required Contents

The evidence package must contain sufficient detail to allow an independent reviewer to determine what baseline was required, which systems it applied to, how implementation was validated, when validation occurred, who approved any deviations, and whether the evidence remains current.

The following evidence items are required.

Evidence Item	Description	Minimum Required Details	Source
Approved server hardening baseline	Current approved baseline for each operating system and server role used in the SWIFT environment	Baseline name, version, owner, approval date, applicable server roles, review date	Configuration standard repository or GRC document library
Server inventory extract	Current list of in-scope SWIFT servers	Hostname, asset ID, IP address, environment, server role, operating system, owner, location, criticality	CMDB, asset register, SWIFT architecture inventory
Baseline applicability matrix	Mapping of each in-scope server to the applicable hardening baseline	Server name, baseline name, baseline version, exception status, validation date	Configuration management records

Evidence Item	Description	Minimum Required Details	Source
Build or rebuild records	Evidence that servers were built from approved images or configuration templates	Build date, image or template version, installer, change ticket, approval reference	Change management system, build platform
Configuration scan results	Automated evidence showing compliance against the approved baseline	Scan date, tool used, policy profile, pass/fail status, failed checks, remediation status	Security configuration assessment tool
Manual hardening checklist	Manual validation where automated testing does not cover all settings	Control area, required setting, observed setting, validator, date, outcome	Infrastructure operations records
Service and port review	Evidence that only required services, listening ports, and protocols are enabled	Hostname, listening ports, business justification, owner approval, scan date	Vulnerability scanner, endpoint tool, network scanner
Local account and privilege review	Evidence that privileged and local accounts are controlled	Account list, privileged group membership, disabled accounts, service accounts, review outcome	Operating system export, privileged access tool
Authentication and session settings	Evidence of secure authentication and administrative session controls	Password or key settings, lockout settings, session timeout, remote access restrictions	Group policy, local security policy, identity platform
Logging and time synchronisation settings	Evidence that audit logs are enabled and timestamps are reliable	Audit policy settings, log forwarding destination, time source, time sync status	SIEM, endpoint agent, server configuration export
Endpoint protection configuration	Evidence that malware protection, host firewall, application control, or equivalent controls are active	Agent status, policy name, last update, last check-in, firewall profile	Endpoint security console
Patch and vulnerability status	Evidence that the server is maintained at an approved security patch level	Patch status, last update, outstanding vulnerabilities, remediation plan	Patch management and vulnerability management tools
Baseline deviation register	Record of approved exceptions or deviations from standard hardening settings	Deviation description, affected servers, risk rationale, compensating controls, approval, expiry date	Risk register, exception register
Remediation evidence	Evidence that failed baseline checks have been corrected or formally accepted	Finding, corrective action, implementation date, re-test result, closure approval	Ticketing system, scan comparison
Periodic review record	Evidence that baselines and system compliance are reviewed on a defined cycle	Review date, participants, conclusions, actions, approval	Security governance records

The evidence package must include the following minimum data fields for each in-scope server:

Field	Required Value
Hostname	[Hostname]
Asset ID	[Asset ID]
Environment	Production / Disaster Recovery / Test / Management
Server Role	[Server Role]
Operating System	[Operating System and Version]
Applicable Baseline	[Baseline Name and Version]
System Owner	[System Owner]
Technical Owner	[Technical Owner]
Last Baseline Validation Date	[Validation Date]
Validation Method	Automated scan / Manual checklist / Configuration export / Combined
Compliance Status	Compliant / Non-compliant / Exception approved / Remediation in progress
Open Deviations	Yes / No
Evidence Location	[Repository Path or Evidence Link]

The hardening baseline evidence should cover, at minimum, the following configuration areas:

Configuration Area	Evidence Expectation
Operating system installation	Minimal installation, approved image or template, removal of unnecessary packages
System services	Only required services enabled; unused services disabled or removed
Network exposure	Only authorised ports and protocols listening; insecure protocols disabled

Configuration Area	Evidence Expectation
Remote administration	Administrative access restricted to approved management paths and authorised administrators
Authentication	Secure account lockout, password, key, and session controls configured
Privilege management	Local administrator and privileged groups restricted and reviewed
Default accounts	Default, guest, unused, or vendor accounts disabled, renamed, removed, or controlled
Service accounts	Service accounts documented, non-interactive where possible, and least-privileged
Host firewall	Host firewall enabled with approved inbound and outbound rules
Malware protection	Endpoint protection enabled, updated, and centrally monitored
Application control	Unauthorised executables, scripts, and tools restricted where supported
Logging	Security, system, authentication, privilege, and administrative events logged
Log forwarding	Logs forwarded to approved monitoring or SIEM platform
Time synchronisation	Servers synchronised to approved time sources
File system permissions	Sensitive directories, configuration files, logs, and keys restricted
Cryptographic settings	Weak protocols, weak ciphers, and insecure legacy settings disabled where supported
Patch configuration	Security updates managed through approved patching process
Backup agent configuration	Backup configuration present where required and protected from misuse
Monitoring agent configuration	Security and operational monitoring agents installed and active
Banner and warning messages	Approved legal or administrative warning banners configured where applicable
Configuration drift control	Ongoing monitoring or periodic validation used to detect unauthorised changes

The evidence must distinguish clearly between:

- The baseline requirement.
- The observed system configuration.
- The validation method.
- The validation result.
- Any remediation or approved deviation.

Example evidence index:

Evidence Ref	Evidence Name	System or Scope	Date Collected	Collected By	Validation Status
EVD-SH-001	Windows Server Hardening Baseline v[Version]	Windows SWIFT servers	[Date]	[Name/Role]	Approved baseline
EVD-SH-002	Linux Server Hardening Baseline v[Version]	Linux SWIFT servers	[Date]	[Name/Role]	Approved baseline
EVD-SH-003	SWIFT Server Inventory Extract	All in-scope servers	[Date]	[Name/Role]	Complete
EVD-SH-004	Baseline Compliance Scan Report	Production SWIFT servers	[Date]	[Name/Role]	Reviewed
EVD-SH-005	Manual Hardening Validation Checklist	SWIFT communication servers	[Date]	[Name/Role]	Reviewed
EVD-SH-006	Open Hardening Deviations Register	Servers with approved deviations	[Date]	[Name/Role]	Approved where applicable
EVD-SH-007	Remediation Closure Tickets	Previously failed baseline checks	[Date]	[Name/Role]	Closed or tracked

Collection & Validation

Evidence must be collected from authoritative systems and reviewed for completeness, accuracy, and currency before it is relied upon for audit or attestation purposes.

Evidence collection must be performed by personnel with appropriate technical knowledge of the SWIFT environment, but validation should include independent review by a person who did not implement the original configuration wherever practicable.

Recommended collection frequency:

Evidence Type	Minimum Frequency	Trigger-Based Collection
Approved hardening baseline	At least annually	Baseline update, new operating system, new server role, material threat or vendor change
Server inventory extract	Quarterly	New server, decommissioned server, environment change
Configuration compliance scan	Quarterly for production and disaster recovery; before go-live for new servers	Build, rebuild, major patching, configuration change, incident, audit request
Manual checklist	At go-live and annually where automated coverage is incomplete	Tool limitation, exception request, high-risk change
Service and port review	Quarterly	New application component, network change, unexpected scan result
Privileged account review	Quarterly	Joiner, mover, leaver event; privilege change; incident
Deviation register review	Monthly for open deviations	Deviation expiry, compensating control change, risk reassessment
Remediation evidence	As remediation is completed	Closure of failed scan item or audit finding

The evidence collection process must include the following steps:

- Confirm the list of in-scope SWIFT servers against the current asset inventory, architecture diagrams, and service ownership records.
- Confirm the applicable hardening baseline for each server based on operating system, role, environment, and technology platform.
- Export or capture the approved baseline documentation from the controlled document repository.
- Run automated configuration compliance scans using the approved toolset where available.
- Collect manual configuration evidence for settings not covered by automated tooling.
- Export supporting evidence from endpoint protection, logging, monitoring, vulnerability management, patch management, and privileged access platforms.
- Identify failed checks, missing evidence, undocumented services, excessive privileges, or unexpected configuration differences.
- Link each exception, deviation, or failed check to an approved risk acceptance, remediation ticket, or compensating control.
- Re-test remediated items and retain the before-and-after evidence.
- Review the final evidence package for completeness and sign off the validation result.

Validation must confirm:

Validation Check	Expected Outcome
Completeness	Every in-scope server has a corresponding baseline, validation result, and evidence reference
Currency	Evidence was collected within the required review period or after the most recent material configuration change
Integrity	Evidence comes from approved sources and has not been manually altered outside the evidence repository

Validation Check	Expected Outcome
Traceability	Evidence can be traced to specific servers, dates, tools, reviewers, tickets, and approvals
Consistency	Baseline names and versions align across inventory, scan reports, and deviation records
Deviation control	All non-standard settings are documented, approved, risk-assessed, and assigned an owner
Remediation tracking	Failed checks are either remediated, scheduled for remediation, or formally accepted
Operational alignment	Hardened settings do not conflict with documented SWIFT operational requirements without approved justification

Evidence must not be considered valid if:

- The server is missing from the asset inventory or baseline applicability matrix.
- The scan report does not identify the system, scan date, policy profile, or result.
- The baseline version used for validation is obsolete and no approved rationale exists.
- Failed checks are present with no remediation ticket, exception, or risk acceptance.
- Manual screenshots or exports are not dated or cannot be tied to a specific server.
- Configuration results have been edited without a clear chain of custody.
- The evidence covers test systems only while production systems are in scope.
- The evidence is older than the required collection period and no revalidation has occurred.

Validation sign-off must be recorded as follows:

Role	Responsibility	Sign-Off Required
Technical Owner	Confirms configuration settings and remediation actions	Yes
SWIFT Infrastructure Owner	Confirms server scope and operational applicability	Yes
Security Operations Representative	Confirms security tooling, monitoring, and endpoint protection evidence	Yes
Risk or Compliance Representative	Confirms evidence completeness and exception governance	Yes
Independent Reviewer	Confirms evidence is suitable for assurance or audit use	Where required

Sign-off record:

Role	Name	Date	Outcome	Comments
Technical Owner	[Name]	[Date]	Approved / Rework required	[Comments]
SWIFT Infrastructure Owner	[Name]	[Date]	Approved / Rework required	[Comments]
Security Operations Representative	[Name]	[Date]	Approved / Rework required	[Comments]
Risk or Compliance Representative	[Name]	[Date]	Approved / Rework required	[Comments]
Independent Reviewer	[Name]	[Date]	Approved / Rework required	[Comments]

Retention & Access

Server hardening evidence must be retained in a controlled repository that protects confidentiality, integrity, and availability. The repository must support access control, version history, audit logging, and recovery in the event of accidental deletion or corruption.

Evidence must be retained for at least [Retention Period] or longer where required by legal, regulatory, contractual, audit, incident response, or internal governance obligations.

Retention requirements:

Evidence Category	Minimum Retention Expectation	Notes
Approved hardening baselines	Current version plus prior versions for [Retention Period]	Required to prove what baseline applied at a point in time
Server inventory extracts	[Retention Period]	Retain periodic snapshots and year-end evidence packs
Baseline compliance scan reports	[Retention Period]	Retain original exports and reviewed summaries
Manual validation checklists	[Retention Period]	Retain signed or workflow-approved records
Deviation and exception approvals	Life of deviation plus [Retention Period]	Retain risk rationale, compensating controls, and expiry decisions
Remediation tickets and re-test evidence	[Retention Period]	Retain evidence of closure and validation
Sign-off records	[Retention Period]	Retain with the evidence package used for assurance or attestation
Audit submissions	[Retention Period]	Retain exactly as submitted, including supporting files

Access to the evidence repository must be restricted to authorised personnel with a business need. Access should be granted based on role and reviewed periodically.

Recommended access model:

Role or Group	Access Level	Purpose
SWIFT Infrastructure Team	Read/write to technical evidence; read to approved baselines	Evidence collection and remediation
Security Operations Team	Read/write to security tool exports and validation comments	Security validation and monitoring evidence
Risk and Compliance Team	Read to all evidence; write to review and sign-off records	Assurance, control review, audit support
Internal Audit	Read-only, time-bound access	Independent review
External Assessor or Auditor	Read-only, time-bound access subject to approval	Assessment or attestation support
General IT Users	No access	Not required

The following handling requirements apply:

- Evidence containing server names, IP addresses, security configurations, vulnerabilities, privileged account details, or security tool outputs must be treated as confidential.
- Evidence must not be emailed externally unless approved by [Information Security Approver] and protected using approved secure transfer methods.
- Screenshots must include sufficient context to show system identity, date, and configuration setting, but should avoid exposing secrets, passwords, private keys, tokens, or unnecessary personal data.
- Exported configuration files must be stored in their original format where possible to preserve integrity.
- If evidence is transformed into a summary, the original export must also be retained.
- Access to evidence must be reviewed at least quarterly and removed promptly when no longer required.
- Any unauthorised access, alteration, deletion, or disclosure of evidence must be reported through the organisation's security incident process.
- Superseded evidence must be archived, not overwritten, where it is needed to demonstrate historical compliance.
- Evidence used for audit or attestation must be frozen or versioned to preserve the exact evidence set reviewed.

Evidence repository details:

Item	Value
Primary Repository	[Evidence Repository Name or Path]
Backup Location	[Backup Location]
Repository Owner	[Repository Owner]
Access Approver	[Access Approver]
Review Frequency	Quarterly
Retention Period	[Retention Period]
Secure Transfer Method	[Approved Secure Transfer Method]